ChatGPT

Privacy Attacks in Blockchain-Based Healthcare Data Sharing

Executive summary

Blockchain can improve the **integrity, accountability, provenance, and distributed enforcement** of healthcare data sharing, but it does not inherently provide confidentiality or anonymity. In fact, the properties that make a ledger auditable—persistent identifiers, replicated transaction histories, timestamps, smart-contract calls, and immutable access events—create a distinctive privacy attack surface. MedRec, for example, represents patient-provider relationships and record pointers through smart contracts, while FHIRChain records access-sharing events and relies on encrypted references to clinical data stored elsewhere. Subsequent research has explicitly demonstrated that such healthcare metadata can reveal doctor-patient relationships and enable linkage attacks even when clinical records themselves are encrypted. [1]

The most consequential threat is therefore often **not "someone decrypts the medical record on the blockchain."** A more realistic attack chain is: observe persistent ledger metadata → cluster identities and interactions → combine them with hospital, physician, genomic, insurance, social, or network-level auxiliary information → infer a patient's identity, treatment relationships, disease category, or participation in a sensitive dataset. Genomic research demonstrates how dangerous auxiliary information can be: surnames have been inferred from nominally de-identified genomes, and genomic Beacon queries have been used to infer membership and associated phenotypic information. [2]

The highest-priority risks for a real healthcare deployment are consequently **metadata/linkage leakage, key or access-control compromise, and compromise of the off-chain data plane**. Smart-contract vulnerabilities, oracle/input manipulation, network deanonymization, malicious consortium members, and validator collusion form a second tier whose importance depends strongly on architecture. Consensus and Sybil attacks are less directly about confidentiality but become privacy attacks when an adversary can censor revocations, manipulate authorization state, corrupt audit provenance, or gain enough replicated observations to correlate users. Hyperledger Fabric reduces classical permissionless Sybil risk through PKI-backed membership, but this changes rather than eliminates the trust problem: certificate authorities, consortium governance, authorized peers, and collusion become privileged attack surfaces. [3]

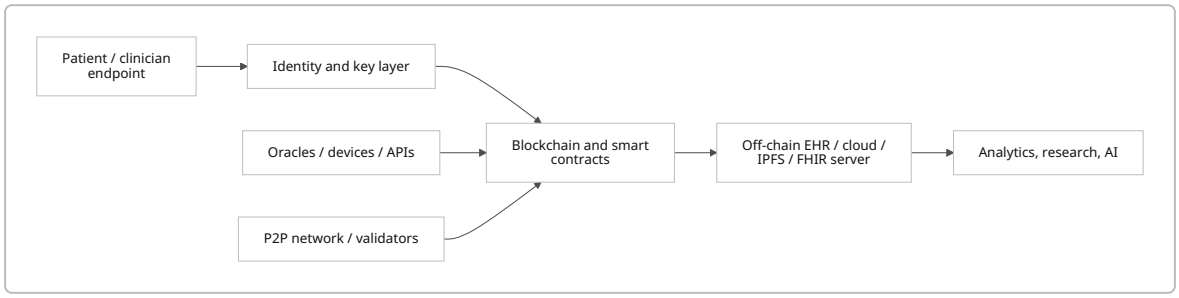
There is also a major **evidence gap** between proposed protection schemes and production clinical systems. A 2025 systematic review covering 334 blockchain-healthcare privacy papers found that most remained at Technology Readiness Level 3; only 29 reached TRL 4, one reached TRL 5, and none reached TRL 6 or above. Consequently, publicly documented privacy failures of deployed healthcare blockchains are much rarer than papers proposing defenses or demonstrating underlying attacks on generic blockchains. This should not be interpreted as evidence that deployed systems are safe; rather, it means the empirical attack surface is insufficiently measured. [4]

The principal design conclusion is that **a blockchain healthcare system should be treated as a multi-layer privacy system, not as a blockchain plus encryption**. Sensitive payloads should normally remain off-chain; even hashes should be treated cautiously because deterministic commitments to

guessable values are susceptible to dictionary/linkage attacks. CNIL recommends, in descending preference, cryptographic commitments, keyed hashes, or strong encryption for personal information recorded on-chain, while retaining plaintext outside the ledger. [5] Zero-knowledge proofs can substantially reduce disclosure at the authorization layer; secure multi-party computation is appropriate for cross-institution computation; differential privacy is useful for aggregate releases; and permissioned ledgers can reduce exposure. None, however, independently conceals transaction timing, network identities, compromised endpoints, malicious authorized users, or false clinical input.

Scope and threat model

A useful abstraction is to divide a blockchain healthcare system into five mutually dependent privacy surfaces:



This distinction matters because many proposed architectures deliberately leave the actual EHR outside the chain. MedRec integrates with providers' local storage and records references and permissions; FHIRChain similarly uses encrypted references rather than placing full clinical content on-chain. Estonia's well-known e-health deployment likewise integrates Guardtime's KSI integrity technology with an Oracle database that stores and processes patient records. In each case, blockchain integrity does **not** imply confidentiality of the underlying clinical repository. [6]

Attacker classes and capabilities

Threat actor	Typical capabilities	Privacy objectives	Particularly relevant attacks
External observer	Scrape a public ledger; inspect contract state/ events; obtain auxiliary public datasets	Identify patients or clinical relationships	Linkage, graph deanonymization, inference, metadata analysis
Network-level adversary	Observe or operate blockchain peers; correlate transaction propagation with IP endpoints	Map blockchain identifiers to organizations/users	P2P deanonymization, timing correlation, side-channels
Curious-but-honest node	Correctly executes protocol but analyzes its replicated ledger/private collection	Learn more than its intended business purpose	Metadata leakage, membership inference, cross-organization linkage

Threat actor	Typical capabilities	Privacy objectives	Particularly relevant attacks
Malicious validator/ node	Reorder, censor, selectively relay, withhold, or propose invalid/ misleading state subject to consensus rules	Manipulate authorization/audit state or increase observations	Consensus attacks, availability attacks, censorship, poisoning
Healthcare insider	Legitimate EHR or smart-contract credentials and contextual clinical knowledge	Access records beyond treatment purpose or identify targeted patients	Access abuse, inference, off-chain leakage, key misuse
Colluding consortium members	Pool ledger views, private metadata, business databases and possibly validator votes	Defeat organizational isolation	Linkage, metadata inference, threshold-policy compromise
Sybil adversary	Creates multiple logical nodes or identities where admission permits it	Influence topology, voting, reputation or observations	Eclipse/ deanonymization, consensus manipulation
Nation-state / global observer	Large auxiliary datasets, telecom/cloud visibility, long-term collection, coercive access to infrastructure	Population-scale re-identification and relationship mapping	P2P deanonymization, linkage, cryptanalytic/ key compromise

This distinction between **curious-but-honest and malicious** parties is especially important. Encryption and private-data channels may protect outsiders while doing nothing against an organization explicitly authorized to receive the data. Fabric Private Data Collections, for example, distribute the actual private data to authorized organizations while putting its hash on every channel peer's ledger. Thus their privacy claim is organizationally scoped rather than equivalent to cryptographic hiding from every consortium member. [7]

Permissioned architectures substantially constrain anonymous participation. Fabric requires network participants to prove identities through its Membership Service Provider and PKI framework. This is a strong defense against unrestricted Sybil creation but places increased security responsibility on certificate issuance, revocation and consortium governance. [8] Douceur's foundational Sybil analysis explains why systems without a trusted identity mechanism cannot generally prevent one physical adversary from presenting many logical identities. [9]

Taxonomy of privacy attacks

The taxonomy below treats an attack as *healthcare-specific* when blockchain characteristics interact with clinical semantics, sensitive auxiliary information, medical identities, or healthcare authorization workflows. Several underlying techniques originated outside healthcare; their transferability is explicitly distinguished from confirmed healthcare incidents.

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Re-identification	Converts a pseudonymous patient identifier or apparently anonymous record into a real identity. Requires auxiliary data, repeated identifiers, distinctive health attributes, or a known genome. Genomic studies show particularly strong auxiliary-identification potential. [10]	Extract addresses/ commitments → derive distinguishing patterns → correlate against registries, clinical schedules, genomes or other datasets → validate identity across transactions.	Identification of patients with stigmatizing disease, genetic risk, mental-health treatment, fertility treatment, etc.	High-confidence one-to-one address mappings; repeated deterministic identifiers; bulk correlation/ query activity.	**Moderate–high** with unlinkable credentials, address rotation, ZK proofs and minimized metadata; **low** if the same semantic transaction pattern remains visible.
Linkage attack	Joins multiple pseudonymous records or transactions belonging to the same patient/ provider. MedRec explicitly models patient-provider relationships; healthcare metadata research shows these relations can leak and support linkage. [11]	Cluster repeated keys, contract calls and timestamps → link provider identity → combine encounters → construct longitudinal patient graph.	Reconstruction of treatment history even without decrypting records.	Address reuse; repetitive grant/revoke patterns; stable patient-provider edges; unusually strong temporal correlations.	**High** only when identifiers *and transaction relationships* are hidden; encryption of payload alone is ineffective.

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Inference attack	Derives unknown sensitive attributes from observable facts. Prerequisite may be only specialist identity, visit timing, dataset membership, medication class, or repeated query responses. Genomic Beacon work demonstrated membership and implied phenotype inference. [12]	Observe metadata/ query results → combine with prior knowledge → compute likelihood of diagnosis/ membership → issue additional observations to increase confidence.	Infers disease, pregnancy, genetic status, participation in a study or clinical pathway.	Systematic query sequences; concentration on one subject/ provider; posterior-risk or uniqueness score increases.	**DP is effective for aggregate/ query interfaces**; padding/ batching and metadata hiding help transactional systems. Ordinary encryption offers little protection.
Metadata leakage	Exposure from timestamps, addresses, contract methods, logs, consent changes, pointers, data sizes or transaction frequency. Solidity state is generally publicly observable on public chains, and FHIRChain deliberately records grant/ revoke/access history. [13]	Monitor contract events → label known providers → infer consultation patterns and record-access frequency.	Reveals relationships and healthcare behavior without revealing EHR plaintext.	Repeated calls around appointments; specialty-specific contract interactions; distinctive event sequences.	**Permissioning, private transactions and ZK can be strong**, but hashes, timing and membership may remain observable.

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Smart-contract vulnerability	Authorization or privacy logic is defeated by programming errors such as missing access checks, unsafe proxies, reentrancy or `tx.origin` authentication. Solidity explicitly warns against `tx.origin` authorization and recommends checks-effects-interactions for reentrancy. [14]	Identify vulnerable method → construct malicious transaction/ callback → alter authorization or obtain a protected pointer/key → retrieve off-chain data.	Unauthorized consent changes, access grants, key exposure or corruption of audit records.	Unexpected role/grant changes, recursive call patterns, abnormal transaction traces, failed/ reverted authorization bursts.	**High with layered controls, audits and formal verification**, but only for modeled software failures; compromised administrators and flawed requirements remain.
Side-channel attack	Sensitive state is inferred from execution time, gas use, calldata/ proof size, transaction frequency, error behavior, peer traffic or storage retrieval patterns.	Submit or observe carefully chosen transactions → compare execution/ network characteristics → infer hidden branch or record class.	Reveals existence/type of record, access behavior or proof outcome.	Input-correlated gas/ latency variation; repeated probing; distinctive failure classes.	**Moderate** through fixed-shape circuits, padding, batching and constant-pattern interfaces; often costly in throughput.

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Consensus/ protocol attack	Sufficiently powerful validators censor, reorder, fork or rewrite state according to the protocol's fault threshold. For permissioned blockchains CNIL recommends explicitly assessing whether a coalition could control more than 50% of chain power. [15]	Corrupt/ collude with validators → censor revocation or reorder authorization → expose/ retain access before finality → manipulate subsequent audit state.	Delayed revocation, corrupted provenance, unavailable emergency records, or unauthorized access depending application semantics.	Divergent finality views, abnormal validator voting, censorship concentrated on one subject, reorganization/ finality anomalies.	**Strong** with appropriately parameterized BFT consensus, independent organizations and checkpoints; weak if administrative domains are not actually independent.
Sybil attack	One adversary creates many apparent participants to influence peer discovery, reputation, voting or availability. [9]	Acquire/create identities → occupy topology or policy threshold → observe/ censor target transactions or manipulate distributed decision.	Increased deanonymization visibility, censorship, corrupted data-source voting.	Sudden peer/ identity creation, shared infrastructure fingerprints, correlated voting/uptime.	**High in well-governed permissioned PKI networks**; residual risk shifts to compromised CAs and fraudulent organizational enrollment. [16]

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Transaction/ network deanonymization	Maps ledger addresses to real identities or IP endpoints. Bitcoin research demonstrated both transaction-graph clustering and P2P-level IP deanonymization; these are cross-domain techniques but directly relevant when healthcare applications use publicly observable chains. [17]	Cluster transaction addresses → run/observe peers → correlate first propagation/ IP → combine with known provider/ network identity.	Links a patient/ clinician to medical smart-contract transactions.	Repeated first-hop correlations, stable source networks, unusually dense graph clusters.	**Moderate** with private network transport, relay separation and application-layer unlinkability; transaction anonymity and network anonymity must both hold.
Data-availability attack / poisoning	Off-chain records can be deleted, withheld or replaced; an oracle/device can submit false but correctly signed clinical information. Blockchain consensus establishes agreement over submitted state, not medical truth. Oracle research identifies external-data providers as potential centralized points of failure. [18]	Remove/ withhold referenced object or submit manipulated measurement → valid hash/ transaction is recorded → downstream contract or clinician acts on corrupted/ unavailable input.	Missing emergency records, false IoT measurements, poisoned research datasets, incorrect automated authorization.	Broken object references; hash mismatch; abrupt data-source deviation; unexpected source quorum; retrieval failures.	**Moderate–high** with replicated storage, signed provenance, source quorum and semantic validation; consensus alone is ineffective against truthful-looking bad input.

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Access-control bypass	Legitimate authorization machinery is bypassed through stolen keys, flawed roles, replay, vulnerable proxies or misconfigured contract policy.	Steal credential/ exploit authorization → invoke legitimate-looking access → receive pointer/ decryption capability → fetch record.	Direct PHI disclosure; malicious grants may appear cryptographically valid.	New-device grants, impossible travel, abnormal clinician volume, unusual role changes or emergency-access use.	**High** with MFA/ HSM-backed keys, least privilege, contextual authorization and independent cryptographic data controls; smart-contract RBAC alone is insufficient.
Off-chain storage leak	The blockchain stores only a pointer/hash while cloud, FHIR, database or decentralized storage contains the actual PHI. MedRec and FHIRChain explicitly depend on off-chain/ provider storage. [19]	Obtain CID/ URL/API reference → exploit public storage, gateway, cloud credentials or endpoint → download record → correlate with on-chain provenance.	Full medical-record disclosure, often much greater than ledger metadata exposure.	Bulk downloads, unexpected gateway requests, abnormal object enumeration, storage ACL changes.	**High when client-side encryption and strong object authorization are correct**, but endpoint compromise remains. Public IPFS content must not be treated as confidential merely because it is content-addressed. [20]

Attack	Description and prerequisites	Representative attack steps	Potential healthcare impact	Detection indicators	Mitigation effectiveness
Cryptographic/ key-management misuse	Weak key storage, deterministic hashing of low-entropy identifiers, poor rotation, shared keys, nonce/ randomness errors or unrecoverable patient keys undermine otherwise sound protocols. CNIL recommends commitments or keyed hashes rather than plain fingerprints for personal data. [5]	Enumerate likely identifier → hash guesses and compare, or compromise private/ decryption key → impersonate patient → authorize/ decrypt records.	Persistent identity linkage, impersonation and potentially irreversible historical exposure.	Reused keys/ nonces, unusual signatures, mass hash matching, authentication from new infrastructure.	**High** with mature key lifecycle management, hardware protection, threshold authorization and recovery; usability becomes a major constraint, particularly for patients.

Two observations follow from this taxonomy.

First, **confidential payload encryption does not solve the dominant metadata problem**. A patient who never puts their diagnosis on-chain may nevertheless disclose that the same persistent identifier interacted repeatedly with an oncology contract, a specialist address, and a pharmacy-related service. Liu et al.'s healthcare-specific metadata work formalizes essentially this problem: doctor-patient relationships themselves become linkage material. [21]

Second, hashing is not synonymous with anonymization. A deterministic hash of an email address, patient number, diagnostic code, or small set of possible record states can often be tested by hashing guesses. This motivates CNIL's preference for hiding commitments or keyed hashes and its recommendation to keep cleartext personal information outside the ledger. [5]

How representative attacks work

Metadata-to-diagnosis linkage

A realistic attack requires no cryptographic break:

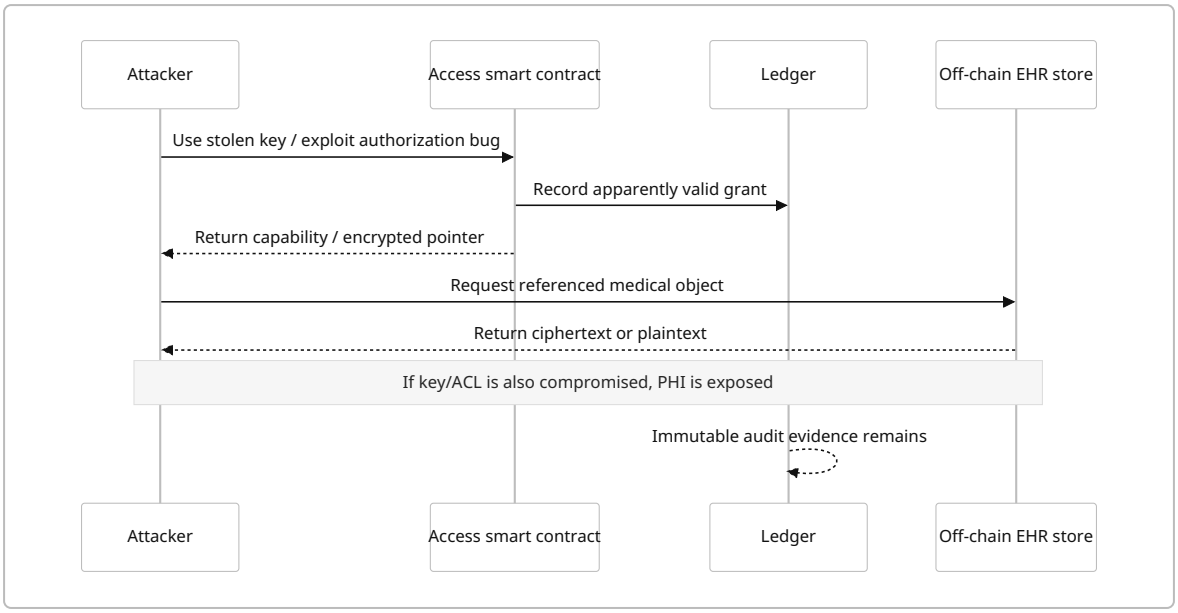


This chain combines mechanisms demonstrated separately in blockchain deanonymization and medical-data re-identification research. Transaction-graph clustering can turn multiple pseudonyms into an entity graph, while network observations can help associate transactions with IP endpoints. Healthcare then provides unusually rich semantic auxiliary data: clinicians have specialties, encounters occur at meaningful times, and genomic or diagnostic information may be highly identifying. [22]

This also illustrates why merely switching from a public to a permissioned ledger does not eliminate metadata risk. It reduces the audience from “everyone” to consortium members, but a curious consortium participant may have **better auxiliary data** than a public observer—for example insurer-provider relationships or provider identifiers.

Access-control-to-off-chain compromise

A second representative chain attacks the separation between blockchain control and external data:



The ledger may make the attack **more auditable without preventing it**. This is an important distinction. FHIRChain deliberately maintains timestamped authorization activity, while Solidity's security guidance makes clear that contract authorization logic must itself be implemented correctly. [23]

In addition, immutable auditability is retrospective. Once an authorized recipient obtains plaintext, neither blockchain revocation nor key deletion can reliably retract copies the recipient has already made. FHIRChain itself acknowledges the broader limitation that trusted participants can misuse data after obtaining legitimate access. [24]

Evidence from academic systems, pilots, and incidents

A critical result of this review is that the evidence should be separated into three categories: **actual ecosystem exploits**, **healthcare deployments/pilots exposing architectural attack surfaces**, and **academic demonstrations of healthcare-specific privacy leakage**. Treating all three as “breaches” would be misleading.

Date	System / event	Evidence and security significance	Observed impact or status
2013	*A Fistful of Bitcoins*	Meiklejohn et al. showed that transaction heuristics can cluster Bitcoin pseudonyms and identify significant economic entities. This is not healthcare-specific but establishes the graph-analysis mechanism relevant to public-chain healthcare. [25]	Empirical deanonymization methodology; no healthcare breach.

Date	System / event	Evidence and security significance	Observed impact or status
2013	Genome surname inference	Gymrek et al. demonstrated surname inference from personal genomes by exploiting Y-chromosome markers and genealogy information. [26]	Demonstrated that nominally de-identified biomedical data can become identifying when auxiliary datasets exist.
2014	Bitcoin P2P deanonymization	Biryukov et al. experimentally linked Bitcoin users/ transactions with IP addresses through peer-level observations. [27]	Cross-domain proof that ledger pseudonymity can be undermined below the application layer.
2015	Genomic Beacon attack	Shringarpure and Bustamante showed that repeated genomic queries could infer whether a target genome was represented and therefore reveal membership/ phenotypic implications. [12]	Concrete medical privacy inference attack; not blockchain-dependent, but directly relevant to blockchain-mediated research-query systems.
2016	**MedRec**	MIT's prototype placed patient-provider relationships, data pointers and permissions in Ethereum contracts while keeping records in providers' local storage; researchers were envisaged as securing a private Ethereum authentication log. [28]	Important architectural case, not a disclosed breach. Persistent relationship metadata later became a recognized privacy concern.
June–July 2016	**The DAO exploit and Ethereum hard fork**	The DAO suffered the canonical recursive-call/ reentrancy exploit; Ethereum subsequently executed a hard fork at block 1,920,000 to recover the affected state. [29]	Real smart-contract incident, but **not healthcare**. It demonstrates that contract-level errors in an Ethereum healthcare control plane can have system-wide consequences.
2016	**Estonian e-health / Guardtime KSI**	Estonia integrated KSI integrity functionality with its Oracle-based health-record infrastructure to strengthen transparency, integrity and auditability. [30]	Production healthcare security deployment. It protects integrity/audit evidence; cited materials do not establish that patient records themselves are stored confidentially “inside a blockchain.” No blockchain-rooted privacy breach is specified.

Date	System / event	Evidence and security significance	Observed impact or status
April 2018 onward	**Synaptic Health Alliance**	The U.S. provider-directory initiative used a permissioned architecture and selected Quorum for its pilot; its own white paper explains that public blockchain pseudonyms cease to be anonymous once an address is linked to an identity. [31]	Real healthcare industry pilot focused on non-proprietary provider information rather than patient PHI. No patient privacy incident is specified in reviewed primary material.
2018	**FHIRChain**	Private-Ethereum prototype tested collaborative decision making for remote cancer care; it used encrypted data references and blockchain authorization/audit events rather than putting full clinical data on-chain. [32]	Prototype/case study; illustrates metadata, key-management and endpoint boundaries. No reported production breach specified.
2019–2020	**MediLedger FDA DSCSA pilot**	Pharmaceutical manufacturers, wholesalers, dispensers and other organizations evaluated a blockchain architecture for package-level drug track-and-trace interoperability. [33]	Real multi-company healthcare/pharma pilot, but not an EHR-sharing deployment. The cited FDA pilot report does not specify a patient-privacy incident.
2022	Healthcare metadata attack analysis	Liu et al. explicitly identified doctor-patient relationships as information leaked by blockchain healthcare metadata and showed that these relationships support linkage inference. [34]	Direct healthcare-specific academic attack model; important evidence that encrypted EHR payloads alone are inadequate.
2025	Systematic maturity assessment	Review of 334 studies found most privacy-preserving blockchain-healthcare systems at TRL 3, 29 at TRL 4, one at TRL 5, and none at TRL 6+. [4]	Strong evidence that clinical-scale empirical security validation remains sparse.

Interpretation. In the primary and high-quality sources reviewed for this report, I did **not** identify a well-documented production incident in which a deployed patient-data blockchain was publicly confirmed to have leaked PHI specifically because an adversary deanonymized its on-chain healthcare metadata. This negative finding is necessarily non-exhaustive. It is also consistent with the unusually low deployment maturity reported by the 2025 systematic review. [4]

That absence should therefore be recorded as **“publicly documented impact: unspecified,” rather than “no risk”** for systems such as MedRec, FHIRChain, Synaptic, and MediLedger. MedRec and

FHIRChain were principally prototypes; Synaptic focused on provider-directory information; and MediLedger focused on the pharmaceutical supply chain rather than longitudinal patient EHRs. [35]

Mitigation effectiveness and privacy–performance trade-offs

No single privacy technology addresses all layers. The correct question is therefore not “Which privacy technology is strongest?” but **“Which leakage channel does it remove, and which one remains?”**

Technique	Attacks mitigated well	Important residual leakage/failure	Privacy	Scalability / latency	Usability / operational burden
Zero-knowledge proofs	Disclosure of attributes, eligibility conditions, authorization predicates and potentially transaction values/ relationships when designed into a shielded protocol	Public inputs, proof timing, transaction occurrence, circuit bugs, key/setup governance depending proof system	**Very high** for proven predicates	**Medium**; succinct verification is possible, but proving/circuit engineering is non-trivial	**Medium–low** unless abstracted from clinicians/ patients
Secure multi-party computation	Cross-hospital statistics or model computation without pooling plaintext	Participant availability, collusion threshold, protocol implementation, traffic patterns	**Very high** for computation inputs	**Low–medium** because communication/ computation can be substantial	**Low–medium** operationally
Differential privacy	Membership/ attribute inference from aggregate research releases and repeated statistical queries	Does not hide a patient's individual blockchain transaction or authorized EHR access	**High for aggregate analytics**, depending privacy budget	**High** computationally	**Medium**, because privacy-budget/utility governance is difficult

Technique	Attacks mitigated well	Important residual leakage/failure	Privacy	Scalability / latency	Usability / operational burden
Conventional/ hybrid encryption	EHR payload disclosure from storage or transport	Addresses, timestamps, contract events, object size, access pattern; authorized recipient can copy plaintext	**High payload confidentiality**	**High**	**High**, provided keys are well managed
ABE / proxy re-encryption	Fine-grained sharing and delegation without re-encrypting data centrally	Attribute/key revocation complexity, proxy trust assumptions, metadata	**High**	**Medium**	**Medium–low** for complex organizations
Permissioned blockchain	Exposure to arbitrary public observers; unrestricted Sybil participation	Consortium insiders, identity metadata, governance collusion, compromised certificate authorities	**Medium–high**	**High** relative to many public chains	**High for institutions**, lower for cross-domain federation
Fabric Private Data Collections / channels	Limits plaintext transaction data to authorized organizations	Hashes remain on channel ledger; authorized organizations receive the underlying private data	**High against unauthorized members**	**High–medium**	**Medium**, policy complexity grows with consortium size
Smart-contract access control	Unauthorized application-layer access when rules and identities are correct	Code bugs, stolen keys, inappropriate legitimate access, off-chain copies	**Medium–high**	**High**	**High** when policy model is simple
Encrypted off-chain storage	Prevents blockchain replication of PHI; reduces immutable sensitive content	Cloud/API compromises, key theft, access-pattern metadata, availability	**Very high if correctly implemented**	**Very high** compared with on-chain EHR storage	**High** with mature infrastructure

Technique	Attacks mitigated well	Important residual leakage/failure	Privacy	Scalability / latency	Usability / operational burden
HSM/KMS/ threshold key management	Credential theft, single-key compromise and some insider abuse	Recovery governance, compromised endpoint before encryption, social engineering	**Very high**	**High**	**Medium–low**, particularly for patient-controlled wallets
Auditing, static analysis, formal verification	Smart-contract defects, policy errors and known vulnerability classes	Semantic specification errors, compromised oracles, insiders, side-channels outside the model	**Indirect but essential**	Development-time cost rather than major runtime cost	**Medium**

Zero-knowledge proofs

ZK proofs are particularly well matched to healthcare authorization because they can replace disclosure such as “send the insurer my diagnosis and age” with a statement such as “prove that the signed medical evidence satisfies this reimbursement rule.” Groth's pairing-based NIZK construction illustrates why ZK became attractive to blockchain systems: proofs can be extremely compact and verification efficient while hiding the witness. [36]

Their limitation is **scope**. A ZK proof can hide a witness while still exposing that the same wallet submitted proofs to an oncology service every Tuesday. Privacy therefore depends on the public-input design, credential unlinkability, transaction layer and network layer, not simply the use of a ZK library. Circuit errors can also convert a cryptographically secure proof system into an insecure application.

For blockchain healthcare, ZK is most compelling for **consent eligibility, credential/role possession, policy satisfaction and selective disclosure**, rather than for trying to represent entire large EHRs inside circuits.

Secure multi-party computation

MPC is stronger than ordinary encryption when several hospitals want a result without any party receiving every hospital's plaintext. The SPDZ family, for example, provides malicious-adversary MPC using an expensive preprocessing phase followed by efficient online computation. [37]

However, protocol security does not imply implementation security. Recent work on concurrent SPDZ implementations identified practical vulnerabilities capable of leaking MAC-related secrets in some implementations, potentially undermining input privacy and output integrity. [38] The broader lesson is directly relevant to healthcare: a proof of a cryptographic protocol's security is not a substitute for implementation-level concurrency, memory, side-channel and deployment testing.

MPC is therefore best reserved for **high-value multi-institution analytics**, not routine individual EHR retrieval.

Differential privacy

Differential privacy is appropriate when a blockchain-mediated research platform repeatedly releases **statistics**, not when one clinician needs one identifiable patient's chart. NIST describes DP as a framework for quantifying privacy loss from data analyses, normally by randomized mechanisms that balance aggregate utility against information leakage. [39]

DP can significantly reduce membership and attribute inference from population queries, including attacks conceptually similar to genomic membership testing, but cannot make an otherwise public access transaction private. Poor composition or an excessively weak privacy budget also defeats its purpose.

Permissioned ledgers and private collections

For clinical workflows, permissioning has a strong practical argument: participants normally already belong to regulated organizations and require authenticated identities. Fabric's MSP model explicitly ties network participation to verifiable identities, while Private Data Collections distribute sensitive data only among organizations specified by collection policy. [40]

The cost is a different trust model. Confidentiality now depends on the authorized consortium subset, PKI, governance and administrators. The hash of private data also remains on every peer's channel ledger in Fabric; depending on input entropy and auxiliary information, even a hash can become a linkage or confirmation oracle. [7]

Hence permissioned blockchain should be described as **exposure reduction**, not anonymity.

Off-chain storage and key management

The safest default is **do not store PHI on-chain**, and do not assume an ordinary unhashed identifier fingerprint is harmless. CNIL specifically recommends commitments first, keyed hashes second, ciphertext third, while storing the underlying personal information outside the blockchain; it also emphasizes secure secret-key storage. [41]

For IPFS-like storage, an additional misconception must be avoided. IPFS's public network does not itself provide medical confidentiality; public content can be retrieved by CID, and normal operation can advertise content identifiers associated with cached or pinned objects. Private medical content therefore requires encryption **before** publication plus carefully controlled key distribution. [42]

Key management should consequently be treated as part of the privacy protocol itself. NIST's key-management guidance emphasizes lifecycle controls rather than encryption-algorithm choice alone. [43] For patient-centric blockchain systems this implies secure enrollment, hardware-backed institutional keys, recovery, rotation, revocation and auditable delegation. A system whose privacy depends on an elderly or acutely ill patient never losing a cryptocurrency-style private key is not operationally robust.

Research gaps and prioritized recommendations

The central research gap is that blockchain-healthcare privacy literature has disproportionately optimized **cryptographic confidentiality under simplified adversaries**, whereas real systems leak through composition: ledger + network + clinical semantics + identity infrastructure + off-chain APIs + institutional insiders. The low TRLs identified across 334 studies provide unusually strong evidence that many claimed privacy properties have not yet survived clinical-scale adversarial validation. [4]

Priorities for practitioners

Highest priority: minimize the ledger's privacy content. Clinical PHI, stable patient identifiers, diagnosis codes, easily guessed fingerprints, human-readable FHIR resources and long-lived access capabilities should not be put on-chain. Where verifiability is required, use hiding commitments or keyed hashes and make the ledger contain the minimum information necessary for consensus. This is consistent with CNIL's privacy-by-design guidance. [5]

Treat metadata as health information. Before deployment, teams should construct an explicit metadata data-flow model covering addresses, organizational membership, contract names/methods, events, timestamps, transaction frequency, gas/size, consent changes, CIDs, access failures and peer-level traffic. Then run graph-linkage attacks against that trace. A design should not receive a “privacy-preserving” label merely because `EHR = Encrypt(data)` appears in the architecture.

Make off-chain infrastructure part of the formal threat model. An encrypted pointer to an insecure FHIR server is not privacy preservation. Production requirements should include client-side or envelope encryption, authenticated APIs, non-public object stores, strict gateway controls, storage replication/backup, deletion procedures, data-loss monitoring, and cryptographically bound provenance. MedRec and FHIRChain demonstrate why this boundary is architectural rather than optional. [19]

Separate authentication from decryption capability. A stolen blockchain signing key should preferably not automatically yield the patient's long-term EHR decryption key. Institutional deployments should use independent KMS/HSM controls, contextual authorization, threshold approval for especially sensitive disclosures, key rotation and recovery procedures. [44]

Prefer permissioned, segmented ledgers for routine clinical exchange unless public verifiability is genuinely required. Public-chain designs need a positive justification because pseudonymity is fragile and network participants cannot be assumed anonymous. Synaptic's own design analysis reached a similar practical conclusion when it selected a permissioned model for its provider-data pilot. [45]

Use ZK, MPC and DP according to leakage channel rather than fashion. ZK should hide attributes/policies; MPC should protect cross-organizational computation; DP should protect released aggregate statistics. None should be presented as a universal “blockchain privacy layer.” [46]

Test malicious and colluding participants, not just outsiders. Healthcare consortia frequently consist of organizations that legitimately possess rich auxiliary datasets. Evaluations should therefore include curious-but-honest insurers, malicious clinicians, compromised certificate authorities, colluding validators, compromised storage administrators and network observers.

Continuously audit the smart-contract control plane. Access-control contracts should be minimized, independently reviewed, fuzzed, tested for authorization invariants, monitored after deployment and

designed with emergency mechanisms. Solidity's own guidance recommends small/modular contracts, peer review, careful interaction ordering and avoidance of `tx.origin` authorization. [14]

Priorities for researchers

The most urgent research need is an **empirical privacy benchmark for blockchain healthcare metadata**. A useful benchmark should provide synthetic but semantically realistic clinical trajectories and measure re-identification/linkability under progressively stronger adversaries: ledger-only → ledger plus provider identities → plus timestamps → plus IP observations → plus insurer/hospital auxiliary graphs. Privacy should be reported quantitatively rather than as a binary feature.

A second priority is **compositional privacy analysis**. Current claims such as “ZK protects identity” or “ABE protects data” frequently ignore leakage from the remaining system. Research should characterize an end-to-end leakage function,

$$L = L_{\text{ledger}} + L_{\text{network}} + L_{\text{storage}} + L_{\text{identity}} + L_{\text{oracle}} + L_{\text{analytics}},$$

where the notation is conceptual rather than implying simple statistical additivity. A system should be evaluated against the *combined* information available to an adversary.

Third, healthcare needs **privacy-preserving accountability with controlled linkability**. Complete unlinkability conflicts with requirements to audit inappropriate clinical access, investigate fraud and support emergency care. Liu et al. explicitly identify this tension between metadata privacy and accountability. [21] Promising designs should therefore support policy-governed or threshold deanonymization rather than making either total transparency or total anonymity the default.

Fourth, **revocation and erasure semantics** remain poorly aligned with immutable audit systems. Removing an off-chain ciphertext or key can make information practically inaccessible, but immutable metadata can continue to reveal that an interaction occurred. CNIL explicitly notes the tension between immutable storage and effective erasure/rectification. [47] Research should distinguish cryptographic erasure of content from persistence of relational metadata.

Fifth, **human-usable key recovery** deserves substantially more attention. Patient sovereignty is not meaningful when losing one private key permanently removes access, while centralized custodial recovery can recreate the single trust point the blockchain was supposed to reduce. Threshold/social/institutional recovery should therefore be evaluated not only cryptographically but under realistic healthcare events such as incapacity, death, guardianship and emergency treatment.

Finally, the field needs **TRL advancement through adversarial clinical pilots rather than additional architecture proposals**. Given that no solution in the 2025 systematic review reached TRL 6+, high-value future studies should expose implementations to red teams, insider simulations, longitudinal metadata collection and clinical usability testing, then publish negative results as well as performance metrics. [4]

The resulting design principle is straightforward but demanding: **blockchain should normally provide integrity, provenance and distributed authorization while privacy is supplied by separate, explicitly composed mechanisms at the identity, transaction, storage, network and analytics layers.** Calling the resulting system “privacy-preserving” is justified only after an adversary is unable to reconstruct sensitive clinical facts from the composition of those layers.

Selected primary and authoritative sources

Zhang et al. — "FHIRChain: Applying Blockchain to Securely and Scalably Share Clinical Data," Computers & Structures Biotechnology Journal, 2018. Architecture and cancer-care prototype using encrypted references, blockchain identities and access logging. [32]

Azaria, Ekblaw et al. — "MedRec: Medical Data Management on the Blockchain," MIT, 2016. Original MedRec architecture, authentication log, patient-provider relationships and provider-local record storage. [28]

Liu et al. — "Metadata Privacy Preservation for Blockchain-Based Healthcare Systems," 2022. Direct analysis of doctor-patient relationship leakage and linkage attacks in blockchain healthcare. [34]

Li, Lohachab, Dumontier & Urovi — "Privacy preservation in blockchain-based healthcare data sharing: A systematic review," Peer-to-Peer Networking and Applications, 2025. Systematic analysis of 334 studies and technology-readiness assessment. [4]

Gymrek et al. — "Identifying Personal Genomes by Surname Inference," Science, 2013. Primary demonstration of genomic re-identification through auxiliary genealogy information. [26]

Erlich et al. — "Identity inference of genomic data using long-range familial searches," Science, 2018. Large-scale demonstration of genomic identity inference from familial information. [48]

Shringarpure & Bustamante — "Privacy Risks from Genomic Data-Sharing Beacons," American Journal of Human Genetics, 2015. Membership and phenotypic-information inference from genomic query interfaces. [49]

Meiklejohn et al. — "A Fistful of Bitcoins: Characterizing Payments Among Men with No Names," USENIX IMC, 2013. Foundational empirical transaction-graph deanonymization study. [25]

Biryukov, Khovratovich & Pustogarov — "Deanonymisation of Clients in Bitcoin P2P Network," 2014. Experimental IP/transaction deanonymization at the peer-network layer. [27]

Douceur — "The Sybil Attack," IPTPS, 2002 / Microsoft Research. Foundational model explaining the identity assumptions behind Sybil resistance. [9]

Ethereum Foundation — DAO exploit and hard-fork communications, 2016. Primary ecosystem documentation of the recursive-call exploit and subsequent hard fork. [29]

Solidity Documentation — "Security Considerations." Official guidance on public contract state, reentrancy, authorization, `tx.origin`, gas/DoS risks and secure design practices. [14]

CNIL — "Blockchain and the GDPR: Solutions for a Responsible Use of the Blockchain," 2018. Authoritative guidance on public identifiers, commitments, keyed hashes, off-chain processing, immutability, key management and permissioned governance. [41]

Hyperledger Fabric Documentation — Membership Service Providers and Security Model. Primary documentation for PKI-backed identity and permissioned participation. [8]

Hyperledger Fabric Documentation — Private Data Collections. Primary description of private-data dissemination to authorized organizations and hashes recorded on channel ledgers. 7

IPFS Documentation — privacy/content-publication guidance. Primary documentation showing that public IPFS content and CIDs should not be assumed confidential and private content requires additional protection. 42

Groth — "On the Size of Pairing-Based Non-interactive Arguments," EUROCRYPT, 2016. Foundational succinct pairing-based zero-knowledge argument construction. 36

Damgård et al. — "Multiparty Computation from Somewhat Homomorphic Encryption," 2011. Foundational SPDZ-style actively secure MPC work. 37

"Rushing at SPDZ: On the Practical Security of Malicious MPC Implementations," 2025. Implementation-level evidence that cryptographically secure MPC designs can still acquire practical privacy/integrity vulnerabilities. 38

NIST SP 800-226 — Differential Privacy Guidelines, 2025. Authoritative treatment of differential privacy, privacy loss and utility trade-offs. 39

NIST SP 800-57 Part 1 Rev. 5 — Recommendation for Key Management, 2020. Key-lifecycle and key-management guidance relevant to healthcare blockchain identities and encryption. 43

Synaptic Health Alliance — "Improving Provider Data Accuracy" white paper. Primary industry description of its permissioned healthcare-provider blockchain pilot and rationale concerning pseudonymity and privacy. 45

MediLedger — FDA DSCSA Pilot Project Final Report. FDA-hosted primary report describing a multi-company blockchain pilot for pharmaceutical package-level tracking and interoperability. 50

Estonian eHealth Foundation / e-Estonia — Guardtime KSI integration, 2016. Primary/official account of integrating blockchain-based integrity and audit mechanisms with the Oracle-based Estonian health-record infrastructure. 30

---

1 6 11 19 28 35 https://viral.media.mit.edu/pub/medrec
https://viral.media.mit.edu/pub/medrec

2 10 26 https://www.science.org/doi/10.1126/science.1229566
https://www.science.org/doi/10.1126/science.1229566

3 8 16 40 https://hyperledger-fabric.readthedocs.io/en/latest/membership/membership.html
https://hyperledger-fabric.readthedocs.io/en/latest/membership/membership.html

4 https://link.springer.com/article/10.1007/s12083-025-02148-9
https://link.springer.com/article/10.1007/s12083-025-02148-9

5 15 41 47 https://www.cnil.fr/sites/cnil/files/atoms/files/blockchain_en
https://www.cnil.fr/sites/cnil/files/atoms/files/blockchain_en

7 https://hyperledger-fabric.readthedocs.io/en/release-2.5/private-data/private-data.html
https://hyperledger-fabric.readthedocs.io/en/release-2.5/private-data/private-data.html

9 https://www.microsoft.com/en-us/research/publication/the-sybil-attack/
https://www.microsoft.com/en-us/research/publication/the-sybil-attack/

12 49 https://pubmed.ncbi.nlm.nih.gov/26522470/
https://pubmed.ncbi.nlm.nih.gov/26522470/

13 14 https://docs.soliditylang.org/en/latest/security-considerations.html
https://docs.soliditylang.org/en/latest/security-considerations.html

17 22 25 A Fistful of Bitcoins: Characterizing Payments Among Men ...
https://www.usenix.org/publications/login/december-2013-volume-38-number-6/fistful-bitcoins-characterizing-payments-among?utm_source=chatgpt.com

18 https://arxiv.org/abs/1808.00528
https://arxiv.org/abs/1808.00528

20 42 https://docs.ipfs.tech/concepts/privacy-and-encryption/
https://docs.ipfs.tech/concepts/privacy-and-encryption/

21 https://www.researchgate.net/publication/360223260_Metadata_Privacy_Preservation_for_Blockchain-Based_Healthcare_Systems
https://www.researchgate.net/publication/360223260_Metadata_Privacy_Preservation_for_Blockchain-Based_Healthcare_Systems

23 24 32 https://pmc.ncbi.nlm.nih.gov/articles/PMC6082774/
https://pmc.ncbi.nlm.nih.gov/articles/PMC6082774/

27 Deanonymisation of clients in Bitcoin P2P network
https://arxiv.org/abs/1405.7418?utm_source=chatgpt.com

29 https://blog.ethereum.org/2016/06/17/critical-update-re-dao-vulnerability
https://blog.ethereum.org/2016/06/17/critical-update-re-dao-vulnerability

30 https://e-estonia.com/ehealth-authority-partners-with-guardtime-to-accelerate-transparency-and-auditability-in-health-care/
https://e-estonia.com/ehealth-authority-partners-with-guardtime-to-accelerate-transparency-and-auditability-in-health-care/

31 45 https://cdn2.hubspot.net/hubfs/4801399/18-SYN-001-Synaptic-Website/downloads/Synaptic_Health_Alliance_Blockchain_White_Paper.pdf
https://cdn2.hubspot.net/hubfs/4801399/18-SYN-001-Synaptic-Website/downloads/Synaptic_Health_Alliance_Blockchain_White_Paper.pdf

33 50 https://www.fda.gov/media/168283/download
https://www.fda.gov/media/168283/download

34 https://dl.acm.org/doi/abs/10.1007/978-3-031-00123-9_33
https://dl.acm.org/doi/abs/10.1007/978-3-031-00123-9_33

36 46 https://eprint.iacr.org/2016/260
https://eprint.iacr.org/2016/260

37 https://eprint.iacr.org/2011/535
https://eprint.iacr.org/2011/535

38 https://eprint.iacr.org/2025/789
https://eprint.iacr.org/2025/789

39 https://csrc.nist.gov/pubs/sp/800/226/final
https://csrc.nist.gov/pubs/sp/800/226/final

43 44 https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final
https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final

48 https://www.science.org/doi/10.1126/science.aau4832
https://www.science.org/doi/10.1126/science.aau4832